

REMEDICATION ENABLEMENT FRAMEWORK

Project Overview and Maturity Model

Purpose

Define a platform-neutral approach for improving what happens after a security assessment, with an initial focus on structured risk acceptance and retest readiness. The framework is intended to be adaptable to different consultancies, security teams, reporting systems and vulnerability-management workflows.

Author: Daniel Jones

Version: 1.0

Status: Portfolio-ready project overview; detailed module specifications maintained separately

Design position: Platform-neutral, human-led, AI-optional

Contents

1	Executive Summary
2	Background and Problem
3	Project Aim and Objectives
4	How the Concept Evolved
5	Current Framework Structure
6	Core Design Principles
7	Reference Operating Model
8	Future Capability Maturity Path
9	Prototype and Validation Plan
10	Key Risks and Constraints
11	Project Deliverables and Current Status
12	Conclusion

1. Executive Summary

Security assessments are effective at identifying weaknesses, explaining technical impact and providing remediation advice. The challenge for many organisations begins after delivery, when findings must be converted into owned decisions, implementation activity, risk treatment and later validation.

The Remediation Enablement Framework is a platform-neutral project designed to improve that post-assessment stage without turning a penetration tester into a business risk owner, project manager or virtual CISO. The current framework deliberately concentrates on two areas that remain close to normal assessment and remediation activity: structured risk acceptance and retest readiness.

The project originally explored a broader AI-assisted remediation roadmap. Further design work identified that organisation-wide prioritisation would require business criticality, budget, risk appetite, ownership and strategic context that may not be available to the assessment consultant. The project was therefore narrowed into lower-risk capabilities that can provide value using approved finding information and client-supplied context, while preserving the broader roadmap as a future maturity path.

Current design position

The framework must work without AI and without dependence on a specific portal, vendor or consultancy process. Automation or AI may be added later only where it improves consistency, efficiency or contextual guidance without taking ownership of security or business decisions.

2. Background and Problem

A security finding is not complete from an operational perspective simply because it has been written into a report. After delivery, the client still has to decide how the finding will be treated, whether remediation is technically and operationally feasible, what evidence should be retained, whether residual risk will be accepted, and when a change is ready for independent validation.

Two recurring points of friction are particularly suitable for structured enablement:

- Risk acceptance can become an ambiguous terminal state. A finding may be marked as accepted even though the underlying weakness remains present, with little visibility of who accepted the risk, why the decision was made, what compensating controls exist or when the decision should be reviewed.
- Retest requests can be poorly prepared. A client may have made a genuine change but may not know what information will help the consultant understand the remediation claim, which assets were changed or whether the request covers the full original scope.

The framework addresses these problems by improving the quality and visibility of the workflow around a finding. It does not change the original assessment conclusion, determine business risk appetite, declare remediation complete without validation or require a particular commercial platform.

3. Project Aim and Objectives

The aim is to define a reusable remediation-enablement model that can be adapted to existing reporting, ticketing, vulnerability-management or client-facing workflows.

The current objectives are to:

- Define a clear responsibility boundary between technical security advice and client-owned business decisions.
- Provide a structured and reviewable process for accepting unresolved security risk.
- Provide a consistent process for preparing a finding for remediation validation or retest.
- Keep every workflow traceable to the original approved finding and known client context.
- Avoid false closure, false assurance and unsupported assumptions.
- Create a design that can operate manually or through normal workflow automation before AI is introduced.
- Preserve a maturity path toward broader assessment-level and cross-assessment remediation planning where the required data, skills and governance exist.

4. How the Concept Evolved

The project developed through four main iterations. The changes were deliberate responses to feasibility, governance and responsibility concerns rather than simple document restructuring.

Iteration	Focus	Key learning / change
1. Broad remediation roadmap	AI-assisted action plan generated from an approved assessment report.	Established the core problem: reports explain what is wrong, but clients may still need help organising what happens next.
2. Structured concept specification	Separated the idea into problem definition, AI input/output rules, mock outputs, governance and packaging.	Made the operating boundaries and review requirements explicit and demonstrated how different assessment types might be supported.
3. Remediation enablement split	Separated near-term quick wins from the broader strategic roadmap.	Recognised that business-aware prioritisation can require risk appetite, budget, service ownership and strategic knowledge outside a tester's normal role.
4. Current framework	Risk Acceptance and Retest Readiness as two platform-neutral modules, with the broader roadmap retained as a maturity path.	Moves the project from a company-specific product concept to a reusable process framework that can be prototyped and adapted independently.

Development principle

Knowledge first, workflow second, AI third. Define what good guidance and decision boundaries look like, standardise the process, then introduce automation only where it adds measurable value.

5. Current Framework Structure

The current version is organised as one parent framework with two detailed modules. Each module can be implemented independently, but both use the same design principles and finding lifecycle.

5.1 Module One: Risk Acceptance for Security Findings

This module provides a structured way to record a client decision to tolerate the remaining risk associated with an unresolved finding. It does not treat acceptance as remediation or technical closure.

Core information includes:

- Reason for acceptance.
- Client-side risk owner or accountable role.
- Compensating controls, where applicable.
- Planned remediation, migration or replacement activity, where relevant.
- Acceptance date and review or expiry date.
- Supporting notes or evidence that explain the decision.

Responsibility boundary

The security consultant explains the finding, technical evidence, known impact and remediation options.
The client or appropriate risk owner decides whether the residual risk is acceptable to the organisation.

5.2 Module Two: Retest Readiness and Evidence

This module helps a client prepare a previously reported finding for independent validation. It defines useful evidence categories, common evidence problems, readiness information and possible validation outcomes while maintaining a strict distinction between evidence and verification.

Useful supporting evidence may include:

- Configuration or policy evidence.
- Version, patch or build information.
- Change-management records.
- Access-control or role-assignment information.
- Firewall, ACL or network-control evidence.
- Application configuration or implementation evidence.
- Current system or client verification output.

Core principle

Evidence supports the retest; it does not replace the retest. A finding should only be recorded as remediated or verified after the agreed validation activity has been completed.

6. Core Design Principles

Principle	Application
Platform-neutral	The framework defines process and control requirements without assuming a specific portal, vendor, SaaS platform or reporting product.
Original finding remains authoritative	The workflow must not silently change the finding title, severity, affected scope, evidence or technical conclusion.
Human accountability	Security validation and business risk ownership remain with appropriately authorised people, not an automated system.
Client ownership of business risk	Risk acceptance, risk appetite, budgets and strategic priorities are client decisions unless a separate advisory service explicitly covers them.
Evidence is contextual, not determinative	Uploaded evidence can improve preparation and understanding but must not automatically close or verify a

Principle	Application
	finding.
Lifecycle visibility	Accepted, deferred, partially remediated and unresolved findings should remain visible and reviewable rather than disappearing from attention.
Proportionate workflow	The framework should reduce friction, not introduce a heavy compliance process around ordinary remediation activity.
AI-optional	The framework must function without AI. AI may assist with summarisation, contextual prompts or completeness checks only within defined boundaries.
Traceability	Where automation is used, outputs should remain traceable to approved findings, client-supplied context and controlled guidance.

7. Reference Operating Model

A practical implementation can treat both modules as branches of the same finding lifecycle. The exact user interface can vary, but the responsibility and decision boundaries should remain consistent.

Stage	Finding lifecycle activity	Primary responsibility
1	Finding is issued through an authorised security assessment or review.	Consultancy / assessment team
2	Client reviews the finding and decides whether remediation will be attempted now, deferred, or considered for risk acceptance.	Client / remediation owner
3A	If risk is accepted, the decision is documented with owner, rationale, controls and review date. The finding remains technically unresolved.	Client / risk owner
3B	If remediation is attempted, the client records what changed, affected scope, exceptions and any useful supporting evidence.	Client / remediation owner
4	A retest or validation request is raised when the client believes remediation is ready for verification.	Client / remediation owner
5	The consultant independently validates the originally affected condition and records the outcome.	Consultancy / consultant
6	The lifecycle continues based on the outcome: verified, partially remediated, unresolved, changed condition, unable to validate, or later risk acceptance.	Client and consultancy within their respective boundaries

The reference model is intentionally implementation-neutral. A future implementation could use a dedicated web application, an existing vulnerability-management platform, a ticketing system, a client portal, or a documented manual process, provided the framework controls and responsibility boundaries are preserved.

8. Future Capability Maturity Path

The broader remediation-roadmap concept remains useful as a future direction. It should mature incrementally because each stage requires more client context, broader judgement and stronger governance.

Stage	Capability	Primary value	Additional requirement	Relative risk
1	Finding-Level Remediation Enablement	Make individual findings easier to understand, accept, manage and retest.	Approved finding data and limited client-supplied context.	Low
2	Assessment-Level Remediation Planning	Group and sequence remediation actions within one assessment.	Implementation constraints and stronger technical advisory judgement.	Low to Medium
3	Cross-Assessment Remediation	Consolidate findings from multiple assessments into common technical workstreams.	Consistent taxonomy, cross-domain context and client isolation.	Medium
4	Business-Aware Prioritisation	Prioritise using criticality, ownership, dependencies and risk appetite.	Business context, budgets, risk information and security advisory capability.	High
5	Strategic Remediation and CISO-Level Advisory	Support organisation-wide programmes, executive decisions and long-term improvement planning.	Full organisational context, governance and appropriately experienced advisory ownership.	High

The current project intentionally stops at Stage 1 for implementation and prototype work. Stages 2 to 5 are retained as a maturity model, not as claims of current capability.

9. Prototype and Validation Plan

The next practical step is to convert the framework into a small, platform-neutral proof of concept. The prototype does not need to replicate a full vulnerability-management platform. It only needs to demonstrate the lifecycle, data capture and responsibility boundaries clearly.

9.1 Planned prototype artefacts

- Risk Acceptance process diagram.
- Retest Readiness process diagram.
- Detailed Risk Acceptance framework specification.
- Detailed Retest Readiness and Evidence framework specification.
- Small interactive prototype using fictional findings and test data.
- Optional public-facing explanatory articles once the technical framework is stable.

9.2 Minimum prototype behaviours

- Display an approved fictional security finding without altering its technical conclusion.
- Allow a user to follow a structured risk-acceptance workflow and keep the vulnerability visibly unresolved.
- Allow a user to record remediation context and prepare a finding for retest.
- Allow optional supporting evidence or notes without treating them as proof of remediation.
- Represent multiple retest outcomes, including partial remediation and inability to validate.
- Demonstrate review dates and reassessment triggers for accepted risk.
- Operate without any mandatory AI component.

9.3 Validation criteria

Criterion	Question
Accuracy	Does the workflow preserve the original finding, scope and technical conclusion?
Boundary clarity	Can a user clearly distinguish consultant responsibilities from client risk ownership?
Usability	Can the process be followed without specialist knowledge of the framework itself?
Proportionality	Does the workflow add useful structure without creating unnecessary administrative burden?
Traceability	Can acceptance, remediation claims, evidence and validation outcomes be related back to the original finding?
Adaptability	Could the process be implemented in a different platform or organisation without redesigning the core framework?
Automation safety	If automation is later introduced, can it assist without making security or business decisions outside its authority?

10. Key Risks and Constraints

Risk	Why it matters	Framework control
False sense of closure	Accepted risk or submitted evidence may be interpreted as proof that the weakness is gone.	Use explicit lifecycle states showing whether the vulnerability remains present and require independent validation for remediation status.
Consultant becomes de facto risk owner	Clients may expect the assessor to approve business risk decisions.	Keep risk acceptance with an authorised client-side owner and limit the consultant to technical explanation and clarification.
Insufficient client context	The framework could appear to know business priorities, ownership or constraints that were never supplied.	Use structured client-supplied fields and identify unknown information rather than inferring it.
Excessive process burden	A heavy evidence or acceptance workflow could make remediation harder rather than easier.	Use proportionate fields, optional evidence where practical and short guidance.
Stale accepted risk	An accepted finding may remain unresolved indefinitely after its assumptions change.	Record review dates and defined reassessment triggers.
Automation overreach	AI or workflow rules may make	Keep AI optional, constrain it to

Risk	Why it matters	Framework control
	unsupported decisions or create false assurance.	explanation and completeness assistance, and prohibit automatic closure or risk acceptance.
Sensitive information handling	Evidence, notes and finding data may contain security-sensitive or personal information.	Apply data minimisation, access control, appropriate retention and secure handling in any implementation.

11. Project Deliverables and Current Status

Deliverable	Status	Purpose
Project Overview and Maturity Model	Current document	Defines the project, its evolution, current architecture, design principles and maturity path.
Risk Acceptance Framework for Security Findings	To be regenerated as platform-neutral specification	Defines the detailed risk-acceptance process, minimum data, responsibilities, review triggers and controls.
Retest Readiness and Evidence Framework	To be regenerated as platform-neutral specification	Defines readiness, useful evidence, consultant validation, outcomes and implementation controls.
Risk Acceptance workflow diagram	Planned	Visual reference process for risk acceptance and reassessment.
Retest Readiness workflow diagram	Planned	Visual reference process from remediation claim through independent validation.
Interactive prototype	Planned	Demonstrates both workflows using fictional findings and platform-neutral interaction patterns.
Public explanatory content	Optional future output	Summarises the frameworks for non-specialist and portfolio audiences once the technical specifications are stable.

12. Conclusion

The Remediation Enablement Framework is intended to improve the period between assessment delivery and the eventual treatment or validation of a security finding. Its current scope is deliberately narrow: make risk acceptance more structured and make retest preparation more consistent without transferring business decisions to the consultant or treating supporting evidence as proof of remediation.

The project retains a broader strategic vision, but it does not assume that organisation-wide remediation planning should be delivered by a penetration tester or automated system. Instead, capability should mature only when the required data, skills, governance and service ownership are present.

The next stage is therefore practical rather than conceptual: regenerate the two detailed module specifications as platform-neutral documents, create the two workflow diagrams, and implement a small prototype that demonstrates the framework using fictional data.